

CO2 Assessment Tool 2

NAME : **UDHAYA KUMAR U**

Reg no : **192424332**

Course Code : **ITA-1408 Ethical Hacking**

1. OSINT-Based Email Enumeration Assessment using theHarvester (20 Marks)

Aim

To perform an Open Source Intelligence (OSINT) assessment on the **tesla.com** domain using **theHarvester** in Kali Linux to identify publicly available email addresses, subdomains, hosts, and IP addresses, and analyze how this information could be misused during the reconnaissance phase of a cyberattack.

Tool Used

- Kali Linux
- theHarvester

Command Executed

theHarvester -d tesla.com -b all

or

theHarvester -d tesla.com -b bing

or

theHarvester -d tesla.com -b crts

Procedure

1. Open Kali Linux Terminal.
2. Verify installation.

theHarvester --version

3. Execute

theHarvester -d tesla.com -b all

4. Wait for OSINT collection.
5. Review the generated output.

Sample Output

Emails Found

support@tesla.com
careers@tesla.com
press@tesla.com
security@tesla.com
privacy@tesla.com
info@tesla.com

Subdomains

shop.tesla.com
careers.tesla.com
auth.tesla.com
energy.tesla.com
developer.tesla.com

Hosts

shop.tesla.com
developer.tesla.com
auth.tesla.com

IP Addresses

104.xx.xx.xx
23.xx.xx.xx

(Actual results will vary.)

Email Categorization

Email Address	Likely Department
support@tesla.com	Customer Support
careers@tesla.com	Human Resources

press@tesla.com	Public Relations
security@tesla.com	Security Team
privacy@tesla.com	Legal & Compliance
info@tesla.com	Administration

Risk Analysis (Defensive Perspective)

Publicly available organizational information can increase exposure to social engineering if not carefully managed.

Potential misuse includes:

1. Spear-Phishing

An attacker could craft emails that appear to come from legitimate organizational contacts or departments identified during reconnaissance.

2. Credential Harvesting

Users could be lured to fake login pages that imitate legitimate company portals.

3. Impersonation

Knowledge of department names and public email formats may be abused to create convincing impersonation attempts.

4. Target Identification

Public role accounts help identify which departments might receive high volumes of external communication.

5. Infrastructure Mapping

Subdomains and publicly visible hosts can reveal internet-facing services that defenders should inventory and secure.

Countermeasures

1. Limit unnecessary publication of employee email addresses.
2. Use role-based contact forms instead of direct email addresses where appropriate.
3. Enable Multi-Factor Authentication (MFA).
4. Provide regular phishing-awareness training.
5. Configure SPF, DKIM, and DMARC to help protect against email spoofing.
6. Continuously monitor for exposed assets using authorized OSINT techniques.
7. Apply least-privilege access controls and strong password policies.

Conclusion

OSINT tools such as **theHarvester** help security teams understand what information about an organization is publicly exposed. Organizations can use these findings to reduce unnecessary exposure and strengthen defenses against phishing and related social engineering attacks.

Screenshots to Include

- Kali Linux Terminal
- theHarvester execution
- Email results
- Subdomain results
- IP address results

2.) Phishing Awareness Simulation using GoPhish (20 Marks)

Aim

To conduct a phishing awareness simulation using **GoPhish** with **dummy employee accounts** in a controlled lab environment and evaluate user awareness through campaign metrics.

Tools

- GoPhish
- Kali Linux
- Dummy Employee Accounts

Procedure

Step 1

Start GoPhish

```
./gophish
```

Step 2

Open

<https://127.0.0.1:3333>

Step 3

Create Email Template

Example

Subject

Password Expiration Notice

Body

Dear Employee,

Your password will expire within 24 hours.

Please update your password using the secure company portal.

Regards,
IT Support

Step 4

Create Landing Page

Example

Company Login Portal

Step 5

Import Dummy Employee Accounts

employee1@testlab.local

employee2@testlab.local
employee3@testlab.local
employee4@testlab.local
employee5@testlab.local

Step 6

Launch Campaign

Campaign Name

Security Awareness Test

Step 7

Monitor Dashboard

Example Metrics

Metric	Result
Emails Sent	20
Delivered	19
Opened	17
Clicked	6
Submitted Credentials	0 (recommended for awareness-only simulations)

Sample Report

Metric	Percent age
Delivery Rate	95%
Open Rate	85%
Click Rate	30%

Observations

- Most employees opened the email.
- A smaller portion clicked the simulated phishing link.
- The results indicate areas where additional awareness training could reduce susceptibility to phishing.

Recommendations

1. Conduct phishing-awareness training every quarter.
2. Encourage verification of unexpected emails.
3. Report suspicious emails immediately.
4. Enable Multi-Factor Authentication.
5. Deploy advanced email filtering.
6. Simulate phishing campaigns periodically.
7. Teach users to verify URLs before entering credentials.

Conclusion

Regular phishing simulations help organizations measure employee awareness and identify opportunities for targeted security education.

Screenshots Required

- GoPhish Login
- Email Template
- User Group
- Campaign
- Dashboard
- Campaign Statistics

3.) Nmap Aggressive Scan on scanme.nmap.org (10 Marks)

Aim

To perform an **Nmap Aggressive Scan** on the authorized test host **scanme.nmap.org** and analyze the discovered services from a defensive perspective.

Command

```
nmap -A scanme.nmap.org
```

Procedure

1. Open Terminal.
2. Execute

```
nmap -A scanme.nmap.org
```

3. Observe results.

Sample Output

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

22/tcp	open	ssh	
--------	------	-----	--

80/tcp	open	http	
--------	------	------	--

9929/tcp	open	nping-echo	
----------	------	------------	--

31337/tcp	open	Elite	
-----------	------	-------	--

Operating System

Linux

Findings

Parameter	Result
Target	scanme.nmap.org
OS	Linux
Open Ports	22, 80, 9929, 31337
HTTP Service	Available
SSH Service	Available

Defensive Risk Analysis

From a defender's perspective, publicly observable service information can inform social engineering attempts. For example, if an attacker knows an organization exposes SSH services and has an IT support team, they might craft phishing emails claiming there is a required SSH key update or system maintenance. The technical details discovered during reconnaissance can make such messages appear more believable, even without exploiting any vulnerability.

Attack Methodology (High Level)

1. Perform authorized reconnaissance.
2. Identify exposed services.
3. Infer organizational technologies.
4. Craft a convincing phishing scenario that references legitimate technologies or support processes.
5. Attempt to persuade users to disclose information or perform unsafe actions.

Defensive Recommendations

1. Conduct regular security awareness training.
2. Verify requests through official communication channels.
3. Keep software and services updated.
4. Restrict unnecessary public exposure of service information where feasible.
5. Monitor logs for reconnaissance activity.
6. Use Multi-Factor Authentication.

7. Implement email authentication (SPF, DKIM, DMARC).
8. Follow the principle of least privilege.

Conclusion

Authorized reconnaissance tools such as **Nmap** help defenders understand their external exposure. Combined with user awareness and secure configuration, organizations can reduce the risk that publicly available information is leveraged in social engineering campaigns.